

LAB 18

FireStorm — Firebase CTF Challenge

Rapport de Reverse Engineering Android
Analyse statique JADX, Hooking Frida, Authentification Firebase

Auteur : Hiba Chagdaly
Application : FireStorm.apk
Package : com.pwnsec.firestorm
Niveau : Medium
Outils : JADX, Frida 16.0.19, Python 3, pyrebase4
Date : Mai 2026
Flag : PWNSEC{C0ngr4ts_Th4t_w45_4N_345y_...}

Table des matières

1	Introduction et Objectifs	2
1.1	Présentation du challenge	2
1.2	Outils utilisés	2
2	Phase 1 — Préparation de l’environnement	3
3	Phase 2 — Analyse Statique avec JADX	5
3.1	Ouverture de l’APK	5
3.2	Méthode Password()	5
3.3	Classe R.string — IDs des ressources	6
3.4	Structure de MainActivity	7
3.5	Extraction de strings.xml	7
4	Phase 3 — Hooking avec Frida	8
4.1	Création du script Frida	8
4.2	Résultat — Mot de passe obtenu	9
5	Phase 4 — Authentification Firebase et Récupération du Flag	11
5.1	Script Python	11
5.2	Flag récupéré	12
6	Résumé et Conclusions	13

1. Introduction et Objectifs

1.1 Présentation du challenge

FireStorm est un challenge CTF Android de niveau Medium. L'application contient une méthode `Password()` qui génère dynamiquement un mot de passe Firebase, mais cette méthode n'est jamais appelée dans le flux normal de l'application.

Objectif

1. Analyser l'APK avec JADX pour identifier la méthode `Password()`
2. Extraire la configuration Firebase depuis `strings.xml`
3. Forcer l'exécution de `Password()` avec Frida pour obtenir le mot de passe
4. S'authentifier sur Firebase avec Python et récupérer le flag

1.2 Outils utilisés

Outil	Rôle	Version
JADX-GUI	Décompilation Java de l'APK	1.5.5
Frida	Hooking dynamique — appel de <code>Password()</code>	16.0.19
Python 3	Authentification Firebase + flag	3.9
pyrebase4	Librairie Firebase Python	latest
ADB	Déploiement sur émulateur	—
Genymotion	Émulateur Android	—

TABLE 1.1 – Outils utilisés dans ce lab

2. Phase 1 — Préparation de l'environnement

Listing 2.1 – Installation et lancement de l'APK

```
1 mkdir ~/lab18 && cd ~/lab18
2 adb connect 169.254.135.101:5555
3 adb install FireStorm.apk
4 adb shell pm list packages | grep -i fire
5 adb shell am start -n com.pwnsec.firestorm/.MainActivity
6 frida-ps -U | grep -i fire
```

```
mobexler@Mobexler ~/lab18
└─> adb connect 169.254.135.101:5555
already connected to 169.254.135.101:5555
mobexler@Mobexler ~/lab18
└─> adb install FireStorm.apk
Success
mobexler@Mobexler ~/lab18
└─> adb shell pm list packages | grep -i fire
package:com.pwnsec.firestorm
package:com.kimimarul3.FireStorm
mobexler@Mobexler ~/lab18
└─> adb shell am start -n com.pwnsec.firestorm/.MainActivity
Starting: Intent { cmp=com.pwnsec.firestorm/.MainActivity }
```

FIGURE 2.1 – Installation de FireStorm.apk et lancement via ADB

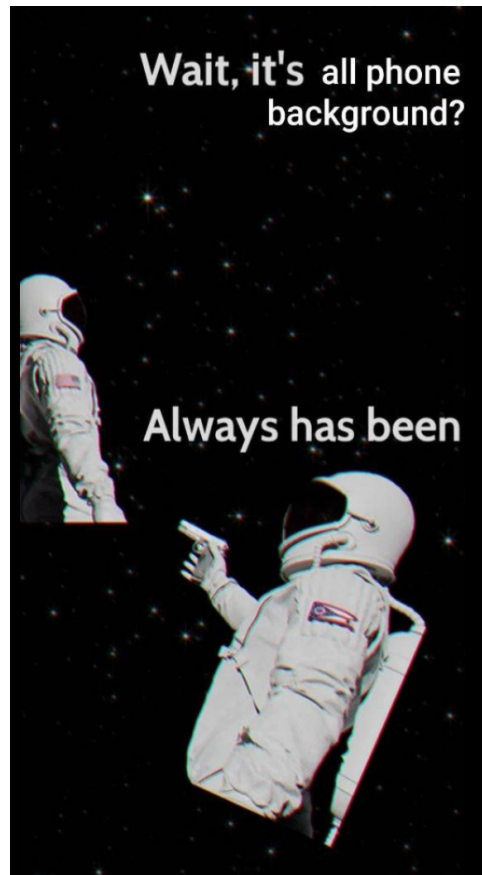


FIGURE 2.2 – Application FireStorm lancée sur l'émulateur

3. Phase 2 — Analyse Statique avec JADX

3.1 Ouverture de l'APK

Listing 3.1 – Lancement de JADX-GUI

```
jadx-gui ~/lab18/FireStorm.apk &
```

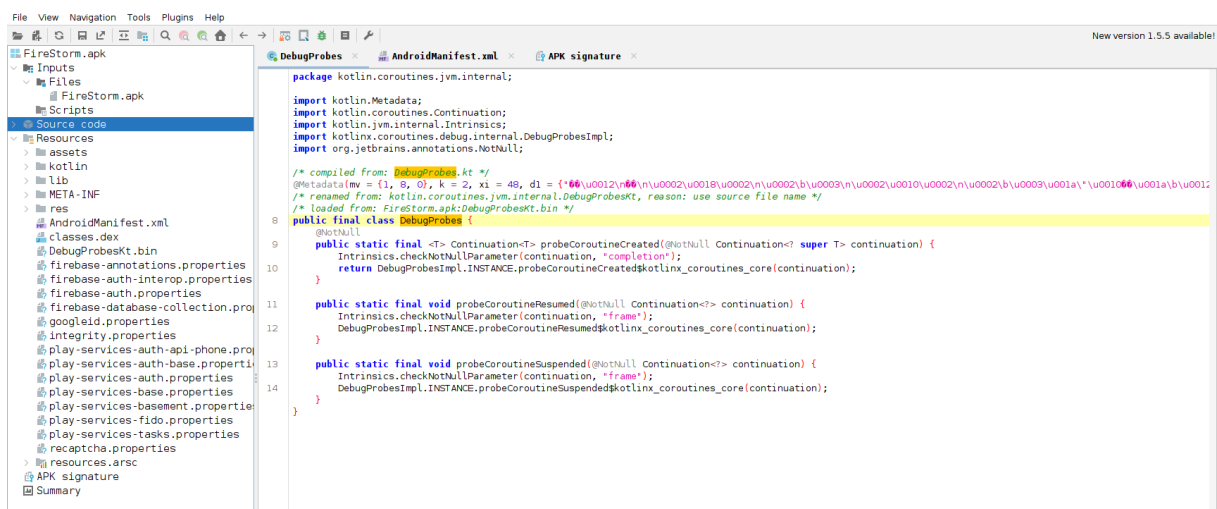


FIGURE 3.1 – JADX — APK FireStorm ouvert, structure des packages visible

3.2 Méthode Password()

Navigation : `com.pwnsec.firestorm` → `MainActivity` → `Password()`

```

public String Password() {
    StringBuilder sb = new StringBuilder();
    String string = getString(R.string.Friday_Night);
    String string2 = getString(R.string.Author);
    String string3 = getString(R.string.JustRandomString);
    String string4 = getString(R.string.URL);
    String string5 = getString(R.string.IDKMaybethewordpassword);
    String string6 = getString(R.string.Token);
    sb.append(string.substring(5, 9));
    sb.append(string4.substring(1, 6));
    sb.append(string2.substring(2, 6));
    sb.append(string5.substring(5, 8));
    sb.append(string3);
    sb.append(string6.substring(18, 26));
    return generateRandomString(String.valueOf(sb));
}

```

FIGURE 3.2 – JADX — Méthode Password() construisant le mot de passe depuis strings.xml

Point clé

La méthode Password() existe dans le code mais **n'est jamais appelée** dans onCreate(), ni dans aucun listener. Elle construit le mot de passe en combinant des strings statiques de strings.xml et une partie générée dynamiquement par generateRandomString().

3.3 Classe R.string — IDs des ressources

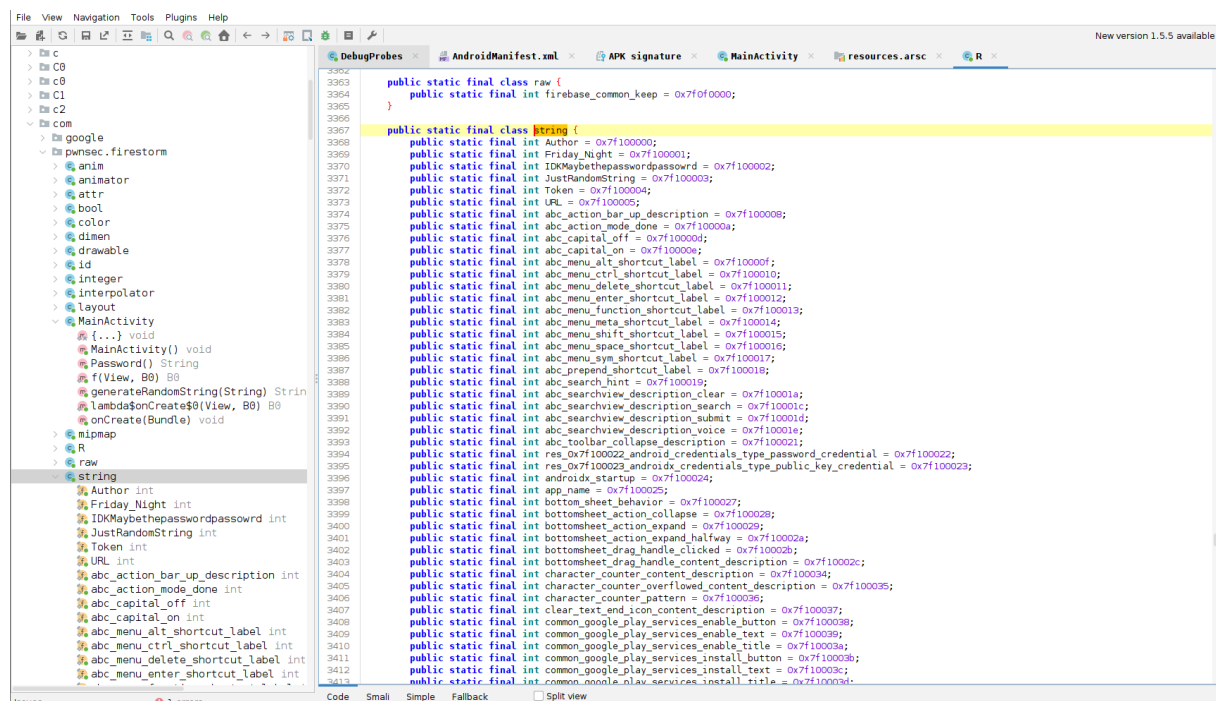


FIGURE 3.3 – JADX — Classe R.string avec les IDs : Author, Friday_Night, IDKMaybethewordpassword, JustRandomString, Token, URL

3.4 Structure de MainActivity

```
public static final class string {
    public static final int Author = 0x7f100000;
    public static final int Friday_Night = 0x7f100001;
    public static final int IDkMaybeThepasswordpassword = 0x7f100002;
    public static final int JustRandomString = 0x7f100003;
    public static final int Token = 0x7f100004;
    public static final int URL = 0x7f100005;
```

FIGURE 3.4 – JADX — Arbre de MainActivity avec Password(), generateRandomString(), onCreate()

3.5 Extraction de strings.xml

```
<?xml version='1.0' encoding='utf-8'?>  
<resources>  
    <string name='Author'>TK757567</string>  
    <string name='Friday_Night'>It's Friday, and PwnSec CTF is here!!!!</string>  
    <string name='IDKeyByThePassword'>Indef:SEY7Noz</string>  
    <string name='JustRandomString'>xor_is_it_random??</string>  
    <string name='Token'>eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyZXZ5bmh0bWUiOiJQd25TdWNBZGlpbSI6bnVzZWZlOmQwQmQiOiIxMTFyMjYxNzEuc2VudC5kaWkiOiJGTFFhOzh2ZDZlcmhhZSIsImV4cCI6MTkxOTg0MDAwfQ==</string>  
    <string name='URL'>https://j0wnsec.xyz/?flag=a7a&id=1</string>
```

FIGURE 3.5 – strings.xml — Configuration Firebase et strings utilisées par Password()

Valeurs extraites de strings.xml

- **Author** : TK757567
- **Friday_Night** : It's Friday, and PwnSec CTF is here!!!!
- **IDKMaybethepasswordpassowrd** : v1n4of.5EY?%0z
- **JustRandomString** : or_is_it_random???
- **URL** : <https://pwnsec.xyz/flag?auth=>
- **firebase_api_key** : AIzaSyAXsK0qsx4RuLSA9C8IPSWd0eQ67HVVHuJY
- **firebase_database_url** : <https://firestorm-9d3db-default-rtdb.firebaseio.com>
- **firebase_email** : TK757567@pwnsec.xyz

4. Phase 3 — Hooking avec Frida

4.1 Création du script Frida

Listing 4.1 – frida_firestore.js — Appel forcé de Password()

```
Java.perform(function() {
  function getPassword() {
    console.log("[*] Recherche instances MainActivity...");
    Java.choose('com.pwnsec.firestore.MainActivity', {
      onMatch: function(instance) {
        console.log("[+] Instance trouvee : " + instance);
        try {
          var pass = instance.Password();
          console.log("[+] Mot de passe Firebase : " +
            pass);
        } catch(e) {
          console.log("[-] Erreur : " + e);
        }
      },
      onComplete: function() {
        console.log("[*] Recherche terminee.");
      }
    });
  }
  console.log("[*] Attente 3 secondes...");
  setTimeout(getPassword, 3000);
});
```

Listing 4.2 – Lancement du script Frida

```
1 frida -U -f com.pwnsec.firestore -l frida_firestore.js
```

```

mobexler@Mobexler ~/lab18
└─ cat > ~/lab18/frida_firestorm.js << 'EOF'
Java.perform(function() {
  function getPassword() {
    console.log("[*] Recherche instances MainActivity...");
    Java.choose('com.pwnsec.firestorm.MainActivity', {
      onMatch: function(instance) {
        console.log("[+] Instance trouvée : " + instance);
        try {
          var pass = instance.Password();
          console.log("[+] Mot de passe Firebase : " + pass);
        } catch(e) {
          console.log("[-] Erreur : " + e);
        }
      },
      onComplete: function() {
        console.log("[*] Recherche terminée.");
      }
    });
  }
  console.log("[*] Attente 3 secondes...");
  setTimeout(getPassword, 3000);
});
EOF

```

FIGURE 4.1 – Création du script frida_firestorm.js

4.2 Résultat — Mot de passe obtenu

```

mobexler@Mobexler ~/lab18
└─ frida -U -f com.pwnsec.firestorm -l frida_firestorm.js

Frida 16.0.19 - A world-class dynamic instrumentation toolkit

Commands:
  help      -> Displays the help system
  object?   -> Display information about 'object'
  exit/quit -> Exit

More info at https://frida.re/docs/home/

Connected to Phone (id=169.254.135.101:5555)
Spawned `com.pwnsec.firestorm`. Resuming main thread!
[Phone::com.pwnsec.firestorm ]-> [*] Attente 3 secondes...
[*] Recherche instances MainActivity...
[+] Instance trouvée : com.pwnsec.firestorm.MainActivity@f1db51f
[+] Mot de passe Firebase : C7_dotpsC7t7f_.In_i.IdttpaofaIIIdIdnndIfC
[*] Recherche terminée.

```

FIGURE 4.2 – Frida — Mot de passe généré : C7_dotpsC7t7f_.In_i.IdttpaofaIIIdIdnndIfC

Mot de passe obtenu

`C7_dotpsC7t7f_._In_i.IdttpaofoaIIdIdnndIfC`

Ce mot de passe est généré dynamiquement par `generateRandomString()` — il change à chaque lancement de l'application.

5. Phase 4 — Authentication Firebase et Récupération du Flag

5.1 Script Python

Listing 5.1 – get_flag.py — Authentication Firebase et lecture du flag

```
import pyrebase

config = {
    "apiKey": "AIzaSyAXsK0qsx4RuLSA9C8IPSWd0eQ67HvHuJY",
    "authDomain": "firestorm-9d3db.firebaseio.com",
    "databaseURL": "https://firestorm-9d3db-default-rtdb.firebaseio.com",
    "storageBucket": "firestorm-9d3db.appspot.com",
    "projectId": "firestorm-9d3db"
}

firebase = pyrebase.initialize_app(config)
auth = firebase.auth()

email = "TK757567@pwnsec.xyz"
password = "C7_dotpsC7t7f_._In_i.IdttpaofoaIIIdIdnndIfC"

user = auth.sign_in_with_email_and_password(email, password)
print("Connexion reussie.")

db = firebase.database()
flag_data = db.get(user['idToken'])
print("FLAG :", flag_data.val())
```

Listing 5.2 – Installation de pyrebase4 et exécution

```
1 pip install pyrebase4 --break-system-packages
2 python3 get_flag.py
```

5.2 Flag récupéré

```

mobexler@Mobexler ~/lab18
└─> sed -i 's/v1n4of.5EY?%0z/C7_dotpsC7t7f_._In_i.IdttpaofoaIIIdnndIfC/' ~/lab18/get_flag.py
python3 get_flag.py
/home/mobexler/.local/lib/python3.9/site-packages/google/auth/__init__.py:54: FutureWarning: You
are using a Python version 3.9 past its end of life. Google will update google-auth with critical
bug fixes on a best-effort basis, but not with any other fixes or features. Please upgrade
your Python version, and then update google-auth.
  warnings.warn(eol_message.format("3.9"), FutureWarning)
/home/mobexler/.local/lib/python3.9/site-packages/google/oauth2/__init__.py:40: FutureWarning:
You are using a Python version 3.9 past its end of life. Google will update google-auth with cr
itical bug fixes on a best-effort basis, but not with any other fixes or features. Please upgra
de your Python version, and then update google-auth.
  warnings.warn(eol_message.format("3.9"), FutureWarning)
/home/mobexler/.local/lib/python3.9/site-packages/google/api_core/python_version_support.py:24
2: FutureWarning: You are using a non-supported Python version (3.9.2). Google will not post an
y further updates to google.api_core supporting this Python version. Please upgrade to the late
st Python version, or at least Python 3.10, and then update google.api_core.
  warnings.warn(message, FutureWarning)
Connexion réussie.
FLAG : PWNSEC{C0ngr4ts_Th4t_w45_4N_345y_P4$$w0rd_t0_G3t!!!_0R_!5_!t??}

```

FIGURE 5.1 – Exécution de get_flag.py — Connexion réussie et FLAG affiché

Flag trouvé !

PWNSEC{C0ngr4ts_Th4t_w45_4N_345y_P4\$\$w0rd_t0_G3t!!!_0R_!5_!

6. Résumé et Conclusions

#	Phase	Description	Statut
1	Préparation	Installation APK, connexion ADB, Frida-server	
2	Analyse JADX	Identification de <code>Password()</code> , <code>strings.xml</code>	
3	Frida hooking	Appel forcé de <code>Password()</code> → mot de passe	
4	Python Firebase	Auth Firebase + lecture DB → flag	

TABLE 6.1 – Récapitulatif des phases

Élément	Valeur
Email Firebase	TK757567@pwnsec.xyz
Mot de passe Frida	C7_dotpsC7t7f_._In_i.IdttpaofoaIIdIdnndIfC
Flag	PWNSEC{C0ngr4ts_Th4t_w45_4N_345y_P4\$\$w0rd_t0_G3t!!!_0R_!5_!t???

TABLE 6.2 – Résultats clés du lab